1. Understanding Security Assessment

Objective

To understand how systems and networks can be evaluated for security weaknesses using **free and open-source tools**.

Explanation

A **security assessment** is the process of analyzing systems, networks, or applications to identify potential security weaknesses. The main goal is to detect vulnerabilities before attackers can exploit them.
Security professionals often follow well-known security frameworks such as **NIST guidelines** to perform structured and standardized assessments.
Security testing can be divided into several types, each focusing on different aspects of system security.

Types of Security Testing

1. Vulnerability Assessment

A vulnerability assessment focuses on identifying known security weaknesses in a system. This is usually done using automated scanning tools that detect outdated software, misconfigurations, or exposed services.
Example tool:

- **OpenVAS** – an open-source vulnerability scanner used to detect security issues in networks and systems.

---

2. Penetration Testing

Penetration testing goes one step further than vulnerability assessment. Instead of only identifying vulnerabilities, it attempts to **simulate real cyberattacks** to determine whether those vulnerabilities can actually be exploited.
Common tools used for penetration testing include:

- Metasploit Framework

- Nmap
- Various tools available in Kali Linux

This type of testing helps security professionals understand the real impact of security flaws.

---

3. Compliance Testing

Compliance testing checks whether systems follow specific security standards and regulatory requirements.

Organizations often use checklists and security benchmarks to verify that their systems are configured properly.

Example resource:

- **CIS Benchmarks**, which provide security configuration guidelines for operating systems, networks, and applications.

---

2. VAPT Methodology

Objective

To understand and follow a **structured methodology for performing Vulnerability Assessment and Penetration Testing (VAPT)** in a systematic and organized way.

Explanation

Vulnerability Assessment and Penetration Testing (VAPT) is carried out in several phases. Each phase focuses on a specific part of the security testing process, starting from planning the assessment to reporting the results. Following a structured methodology helps security professionals perform assessments efficiently and document their findings properly.

Phases of VAPT

1. Planning Phase

The planning phase is the first step of the VAPT process. In this stage, the scope and objectives of the security assessment are defined. This includes identifying the systems that will be tested and setting clear boundaries for the assessment.
Important tasks in this phase include:

- Defining the target systems or applications
- Determining the type of testing to be performed
- Obtaining proper authorization for testing

Tools such as **Dradis Community Edition (Dradis CE)** can be used to organize project information and documentation during the assessment.

---

2. Discovery Phase

The discovery phase focuses on gathering information about the target system. During this stage, security testers scan the network and identify open ports, running services, and potential vulnerabilities.
Common tools used in this phase include:

- **Nmap** – used for network scanning and identifying open ports and services
- **OWASP ZAP** – used for scanning web applications and detecting vulnerabilities such as SQL injection or cross-site scripting

This phase helps testers understand the system architecture and identify potential entry points for attacks.

---

3. Attack Phase

In the attack phase, the vulnerabilities discovered during scanning are tested to see if they can be exploited. This helps determine the real impact of the identified weaknesses.
One of the most commonly used tools in this stage is the **Metasploit Framework**, which allows testers to run exploits against vulnerable services.
The goal of this phase is to confirm whether a vulnerability can be used to gain unauthorized access or control of the system.

---

4. Reporting Phase

The reporting phase is the final stage of the VAPT process. In this step, all findings from the assessment are documented clearly.
The report typically includes:

- Description of vulnerabilities found
- Severity level of each vulnerability
- Evidence such as screenshots
- Recommended solutions to fix the issues

Security professionals often use reporting templates from platforms such as **Pentest-Tools** to create structured and professional reports.

How to Learn VAPT Methodology

Students and beginners can practice VAPT by following the **OWASP Web Security Testing Framework**. This framework provides a structured guide for testing web applications and understanding common security vulnerabilities.

---

3. Security Standards & Compliance

Objective

To understand how security assessments align with **industry regulations and security standards** that help organizations protect sensitive data and maintain proper security practices.

Explanation

Security standards and compliance frameworks provide guidelines for organizations to secure their systems, networks, and data. These standards help ensure that companies follow best practices for information security and protect sensitive information from cyber threats.
Organizations often perform security assessments and audits to verify that their systems meet these regulatory requirements.

Common Security Standards

1. GDPR (General Data Protection Regulation)

GDPR is a data protection regulation implemented by the European Union. It focuses on protecting the personal data and privacy of individuals. Organizations that collect or process personal data must follow strict guidelines for data protection and user privacy.

---

2. HIPAA (Health Insurance Portability and Accountability Act)

HIPAA is a regulation designed to protect sensitive healthcare information. It requires healthcare organizations to implement strong security controls to protect patient data and maintain confidentiality.

---

3. ISO 27001

ISO 27001 is an international standard for information security management systems (ISMS). It provides a framework for organizations to manage risks related to information security and implement appropriate security controls.

How to Learn Security Compliance

One of the best ways to understand common web security risks is by studying the **OWASP Top 10**.

The OWASP Top 10 is a widely recognized list of the most critical web application security vulnerabilities. It helps security professionals identify and prioritize common risks such as:

- Broken access control
- Injection attacks (e.g., SQL injection)
- Security misconfiguration
- Cross-site scripting (XSS)
- Authentication failures

Learning these vulnerabilities helps security testers focus on the most important security issues during assessments.

4. Risk Assessment Basics

Objective

To understand how to **prioritize vulnerabilities using scoring systems** so that the most critical security issues can be fixed first.

Explanation

Risk assessment is an important part of vulnerability management. After vulnerabilities are discovered during a security assessment, they must be evaluated based on their **severity, likelihood of exploitation, and potential impact** on the system.

This process helps security professionals determine which vulnerabilities require immediate attention and which ones can be addressed later.

CVSS Calculator

The **Common Vulnerability Scoring System (CVSS)** is widely used to measure the severity of security vulnerabilities. It assigns a numerical score to each vulnerability based on factors such as exploitability, impact, and complexity.

Security analysts often use the **NVD CVSS Calculator** to determine the severity score of a vulnerability.

CVSS scores generally fall into the following categories:

- **Low:** Minimal impact on the system
- **Medium:** Moderate security risk
- **High:** Serious vulnerability that should be addressed quickly
- **Critical:** Extremely dangerous vulnerability that requires immediate action

Using CVSS scores helps organizations understand the **level of risk associated with each vulnerability**.

Risk Matrix

A **Risk Matrix** is another method used to categorize vulnerabilities based on their **likelihood and impact**.

Security teams often classify vulnerabilities into categories such as:

- **High Risk**
- **Medium Risk**
- **Low Risk**

A simple risk matrix compares:

- **Likelihood of exploitation**
- **Impact on the system or organization**

Tools such as **Google Sheets or Microsoft Excel** can be used to create risk matrices and track vulnerabilities during a security assessment.
This method helps security teams prioritize remediation efforts and focus on the most critical security threats first.

---

5. Common Vulnerabilities

Objective

To identify common security flaws in systems and applications by practicing with cybersecurity labs and tools.

Explanation

During a security assessment, analysts often encounter different types of vulnerabilities that may expose systems to cyberattacks. Understanding these vulnerabilities helps security professionals detect and prevent potential threats.
Vulnerabilities can occur in both **network infrastructure** and **web applications**, making it important to analyze each area carefully.

Network Vulnerabilities

Network vulnerabilities are weaknesses that exist within network services, configurations, or exposed ports. These vulnerabilities can allow attackers to gain unauthorized access to systems or disrupt network operations.
Common examples include:

- **Misconfigured services**

- **Open or unnecessary ports**
- **Outdated network services**
- **Weak authentication mechanisms**

Security professionals often use tools like **Nmap** to scan networks and identify open ports and running services. This helps detect potential entry points that attackers could exploit.

Web Application Vulnerabilities

Web applications are also common targets for attackers. Poorly developed or improperly secured applications may contain vulnerabilities that allow attackers to manipulate or access sensitive data.

Some common web vulnerabilities include:

SQL Injection (SQLi)

SQL Injection occurs when attackers insert malicious SQL queries into input fields to manipulate a database.

Cross-Site Scripting (XSS)

XSS allows attackers to inject malicious scripts into web pages, which can affect users visiting the application.

Students and security testers can practice identifying these vulnerabilities using training platforms such as **OWASP Juice Shop**, which is a purposely vulnerable web application designed for learning web security.

How to Learn Vulnerability Testing

To understand vulnerabilities in a practical way, should practice in safe lab environments. Some commonly used platforms include:

- **Metasploitable** – an intentionally vulnerable virtual machine designed for security training.
- **VulnHub** – a platform that provides downloadable vulnerable machines for penetration testing practice.

These labs help to gain hands-on experience in identifying, analyzing, and exploiting vulnerabilities in a controlled environment.

6. Documentation Fundamentals

Objective

To learn how to create clear and professional security reports using appropriate documentation tools.

Explanation

Documentation is an important part of any cybersecurity assessment. After identifying vulnerabilities and performing testing, all findings must be recorded and presented in a clear and structured report. Proper documentation helps security teams, developers, and management understand the issues and take the necessary steps to fix them.

Good documentation should include details such as the identified vulnerabilities, affected systems, evidence of the issue, and recommended solutions.

Tools for Documentation

Several tools can help security professionals organize and document their findings during vulnerability assessments and penetration testing.

Dradis Community Edition (Dradis CE)

Dradis CE is a collaborative reporting tool that helps security teams manage assessment data and generate structured reports.

CherryTree

CherryTree is a note-taking application that allows testers to record technical findings, commands used, and observations during security testing.

In addition to these tools, security analysts can also use standard documentation tools such as **Microsoft Word, Google Docs, or Excel spreadsheets** to organize and present their findings.

How to Learn Documentation

One effective way to learn security reporting is by using free penetration testing report templates available on GitHub. These templates provide a professional structure for documenting vulnerabilities, risk levels, and remediation recommendations.

---

7. Setup Testing Environment

7.1 Install VirtualBox

First install the virtualization software.

Step 1: Download VirtualBox

1. Go to the official website of
   Oracle VM VirtualBox
2. Download **VirtualBox for Windows Hosts**.

Step 2: Install

1. Run the downloaded .exe file.
2. Click **Next** → **Next** → **Install**.
3. Allow network driver installation.
4. Click **Finish**.

7.2 Install Kali Linux VM

You will use Kali as the **attacker machine**.

Step 1: Download Kali Linux VirtualBox Image

1. Go to
   Kali Linux official downloads page.
2. Download **Kali Linux VirtualBox Image (.7z file)**.

Step 2: Extract the File

1. Install **WinRAR or 7-Zip**.
2. Extract the downloaded .7z.
3. You will get a folder containing:

Kali-Linux.vbox

Kali-Linux.vdi

Step 3: Import Kali into VirtualBox

1. Open VirtualBox.
2. Click **Machine** → **Add**.
3. Select the file:

Kali-Linux.vbox

4. Kali VM will appear in the VM list.

Step 4: Start Kali Linux

Click **Start**.

Default login:

Username: kali

Password: kali

7.3 Download Metasploitable 2

This will be your **vulnerable target machine**.

Step 1: Download

Download **Metasploitable 2** from:

https://sourceforge.net/projects/metasploitable/

Download file:

metasploitable-linux-2.0.0.zip

Step 2: Extract

Extract the zip file.

You will see:

Metasploitable.vmdk

7.4 Create Metasploitable VM in VirtualBox

Step 1: Create New VM

Open VirtualBox → Click **New**

Settings:

Name: Metasploitable2

Type: Linux

Version: Ubuntu (32-bit)

Click **Next**

Step 2: Set RAM

Recommended:

RAM: 4024 MB

Click **Next**

Step 3: Use Existing Disk

Select:

Use existing virtual hard disk file

Choose:

Metasploitable.vmdk

Click **Create**

7.5 Configure Network

Both machines must be on the **same internal network**.

Step 1: Kali Network

VirtualBox → Kali → **Settings** → **Network**

Adapter 1 → Host-Only Adapter

Step 2: Metasploitable Network

VirtualBox → Metasploitable → **Settings** → **Network**

Adapter 1 → Host-Only Adapter

7.6 Start the Machines

Metasploitable 2

Kali Linux

---

8. Vulnerability Scanning

8.1 Objective

Identify vulnerabilities in the target machine (**Metasploitable 2**) using vulnerability scanning tools.

8.2 Scan using OpenVAS

Step 1: Start OpenVAS (GVM)

Open terminal in Kali and run:

sudo gvm-start

This starts the **Greenbone Vulnerability Manager (OpenVAS)** services.

You will see something like:

gsad is running on *https://127.0.0.1:9392*

Step 2: Open the Web Interface

Open your browser in Kali and go to:

https://127.0.0.1:9392

Login credentials:

Username: admin

Password: (created during setup)

Step 3: Create a Target

1. Go to **Configuration**
2. Click **Targets**
3. Click **New Target**

Fill:

Name: Metasploitable2

Hosts: 192.168.56.101 (Metasploitable IP)

Port list: All TCP and Nmap top 100 UDP

Click **Save**

Step 4: Create a Scan Task

1. Go to **Scans**
2. Click **Tasks**
3. Click **New Task**

Configure:

Name: Metasploitable Scan

Scan Config: Full and Fast

Target: Metasploitable2

Scanner: OpenVAS Default

Click **Create**

Step 5: Start the Scan

Click the **Play** icon to start scanning.

The scan may take:

10–30 minutes

8.3 Scan Results

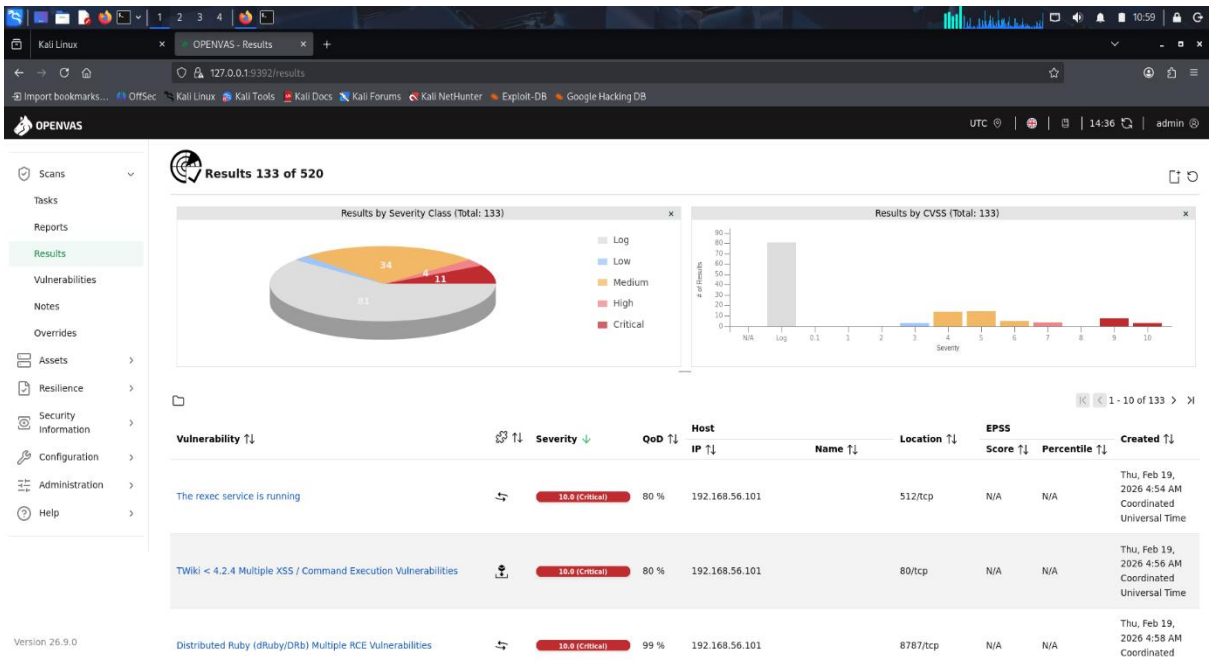

Figure 1: Vulnerability Result

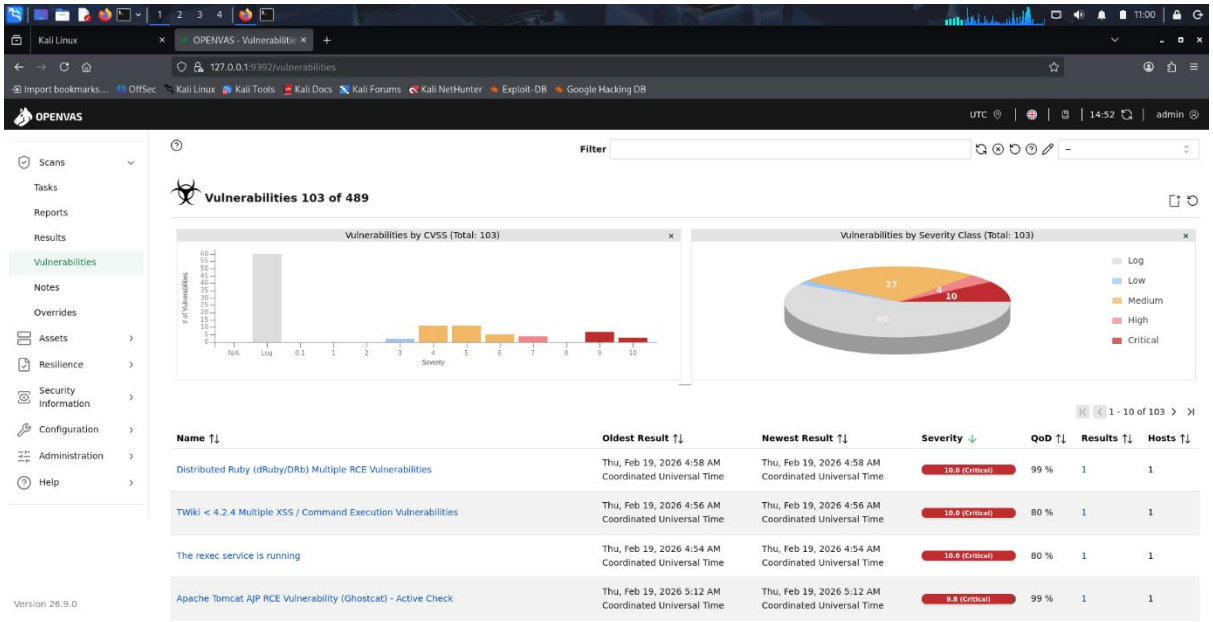

Figure 2: Detailed list

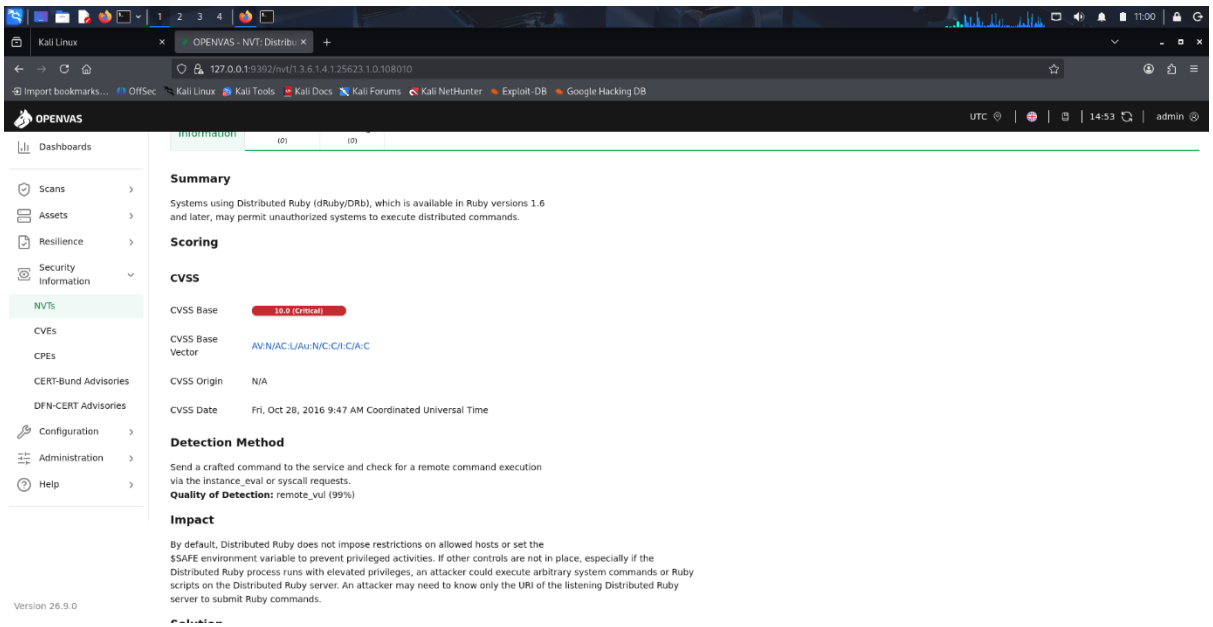

Figure 3: CVSS Detail

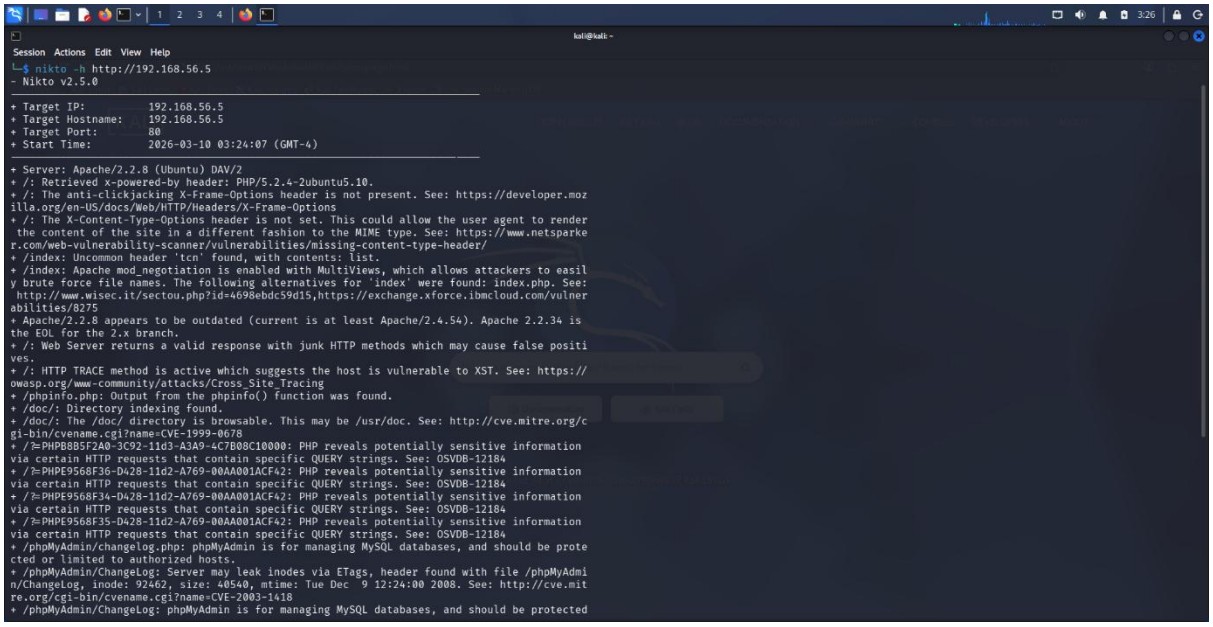

Figure 4: Nikto result

9. Vulnerabilities from Metasploitable2 scan

Vulnerability	Service	CVE	CVSS Score	Severity
VSFTPD Backdoor	FTP	CVE-2011-2523	10.0	Critical
Samba Remote Command Execution	SMB	CVE-2007-2447	9.8	Critical
UnrealIRCd Backdoor	IRC	CVE-2010-2075	9.8	Critical
Apache Directory Listing	HTTP	—	5.0	Medium
Outdated PHP Version	HTTP	Multiple	7.5	High

10. Prioritization for Metasploitable2

Vulnerability	Likelihood	Impact	Risk Level
VSFTPD Backdoor	High	High	Critical
Samba RCE	High	High	Critical

Vulnerability	Likelihood	Impact	Risk Level
UnrealIRCd Backdoor	High	High	Critical
PHP Outdated	Medium	High	High

11. Conclusion

The security assessment of the Metasploitable2 environment revealed several high-risk vulnerabilities that could allow attackers to compromise the system. Implementing proper **patch management, service hardening, and secure configurations** will significantly improve system security.

12. Sources Consulted

Vulnerability	Fix	Patch Link
VSFTPD Backdoor	Upgrade FTP server	https://security.appspot.com/downloads/vsftpd-2.3.4.tar.gz
Samba RCE	Update Samba version	https://www.samba.org/samba/security/
UnrealIRCd Backdoor	Upgrade IRC server	https://www.unrealircd.org/downloads/
Apache outdated	Install latest Apache	https://httpd.apache.org/download.cgi
PHP outdated	Upgrade PHP	https://www.php.net/downloads.php

- OWASP
- OpenVAS
- Nikto